

# SIMATS ENGINEERING ASSESSMENT TOOL 01

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1405

---

## COURSE OUTCOME COVERED

**CO4:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

---

QUESTIONS: 01

Total Marks:100

### Annexure A SECURITY TESTING SIMULATION TASK

---

#### Code of Conduct:

*I V.Bala Siva Prasad Reddy(192424316)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.*

**Signature of the student: V.Bala Siva Prasad Reddy**

| S.No. | Assessment Criterion                                 | Excellent                                                                                                                                                           | Good                                                                                     | Satisfactory                                                           | Needs Improvement                                                                          | Marks |
|-------|------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|-------|
| 1     | Tool Selection and Configuration(20)                 | Selects appropriate open-source tools, configures them correctly, and clearly explains the purpose of each tool.                                                    | Selects suitable tools and configures them with minor errors or limited explanation.     | Uses basic tools with partial configuration and limited understanding. | Selects inappropriate tools or fails to configure them correctly.                          |       |
| 2     | Testing Procedure and Execution(20)                  | Follows a systematic, authorized, safe, and well-documented testing procedure within the approved scope.                                                            | Performs the major testing steps correctly with minor omissions.                         | Completes only basic testing steps with limited documentation.         | Testing procedure is incomplete, unsafe, unauthorized, or poorly executed.                 |       |
| 3     | Identification and Validation of Vulnerabilities(20) | Accurately identifies vulnerabilities, manually validates findings, and distinguishes confirmed issues from false positives.                                        | Identifies and validates most important findings with minor gaps.                        | Identifies basic vulnerabilities but provides limited validation.      | Findings are inaccurate, unsupported, or based only on automated tool output.              |       |
| 4     | Risk Analysis and Remediation(20)                    | Clearly explains the cause, likelihood, impact, severity, and practical remediation for every confirmed vulnerability.                                              | Provides suitable risk analysis and recommendations with minor omissions.                | Provides general risk descriptions and basic remediation measures.     | Risk ratings are unsupported or recommendations are impractical or unrelated.              |       |
| 5     | Evidence, Report Quality, and Ethical Compliance(20) | Provides clear commands, screenshots, outputs, tables, references, and a professional report while maintaining authorization, confidentiality, and ethical conduct. | Provides sufficient evidence and a well-organized report with minor presentation issues. | Provides limited evidence or an adequately organized report.           | Evidence is missing, the report is unclear, or ethical and legal requirements are ignored. |       |
|       |                                                      |                                                                                                                                                                     |                                                                                          |                                                                        | Total                                                                                      |       |

## Annexure A

### NOTE:

- Any testing performed outside the faculty-approved laboratory target, authorized scope, or permitted time must be treated as a serious violation. Destructive testing, denial-of-service activities, unauthorized password attacks, data modification, and testing of public or third-party systems are strictly prohibited.
- Use any Suitable Open Source Tool

### Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

**Aim :** To perform a basic security assessment of an authorized web server by gathering network information, identifying open ports and services, detecting web technologies, examining HTTP headers, scanning for vulnerabilities, and discovering hidden directories and files.

### Target :

- a. **Target IP:** 192.168.56.102
- b. **Target:** Metasploitable 2

**Tools Used :** Ping, Traceroute, Netstat, Nmap, WhatWeb, Curl, Wget, Nikto, Gobuster and Dirb.

## Procedure and Commands

### 1. Network Reconnaissance :

- a. `ping -c 4 192.168.56.102`
- b. `tracert 192.168.56.102`
- c. `netstat -tuln`

- ☐ Ping confirmed that the target was reachable with 0% packet loss. Traceroute was used to examine the path to the target, and Netstat displayed listening network connections.

### 2. Port and Service Identification :

- a. `nmap 192.168.56.102`
- b. `nmap -sV 192.168.56.102`

- ☐ Nmap identified open ports and services. The scan identified ports such as 135, 139 and 445, associated with MSRPC, NetBIOS and Microsoft-DS/SMB services.

### 3. Web Technology Identification : `whatweb http://192.168.56.102`

- ☐ WhatWeb identified Apache 2.2.8, Ubuntu Linux, PHP 5.2.4 and WebDAV. The web page returned HTTP status 200 OK.

### 4. HTTP Header Analysis :

- a. `curl -I http://192.168.56.102`
- b. `wget --server-response --spider http://192.168.56.102`

- ☐ The HTTP response revealed information such as the Apache version, Ubuntu platform and PHP version. This represents information disclosure that can assist server fingerprinting.

### 5. Web Vulnerability Scanning : `nikto -h http://192.168.56.102`

- Nikto was used to identify common web-server configuration problems, outdated components, exposed resources and other potential security issues.

#### 6. Directory and File Discovery :

- a. `gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt`
  - b. `dirb http://192.168.56.102`
- Gobuster and Dirb were used to identify accessible directories and files that may not be directly visible from the main webpage.

#### Observations :

- The target was reachable from Kali Linux.
- Several network services were exposed.
- Apache and PHP versions were disclosed.
- WebDAV was detected.
- HTTP response headers revealed server technology information.

#### Findings and Severity :

| Finding                       | Severity |
|-------------------------------|----------|
| Server/PHP version disclosure | Low      |
| Outdated Apache/PHP versions  | High     |
| WebDAV exposure               | Medium   |
| Exposed directories/resources | Medium   |
| Unnecessary network services  | Medium   |

#### Recommendations

- Upgrade outdated Apache and PHP versions.
- Hide unnecessary server and framework version information.
- Disable WebDAV if it is not required.
- Remove unnecessary services and close unused ports.

- Configure appropriate HTTP security headers.
- Regularly perform vulnerability scanning and server hardening.

```

Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$
kali@kali:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:03:b0:b5 brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 49729sec preferred_lft 49729sec
   inet6 fe80::3200:1f3b:f126:b26/64 scope global dynamic noprefixroute
       valid_lft 45814sec preferred_lft 13814sec
   inet6 fe80::8cb:29f7:7ba:d5c7/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:03:b0:b5 brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
       valid_lft 520sec preferred_lft 520sec
   inet6 fe80::6122:7125:4204:0949/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 4e:28:5f:c2:1d:b4 brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.0.255 scope global docker0
       valid_lft forever preferred_lft forever

kali@kali:~$ ping -s 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
 64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=2.82 ms
 64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=0.713 ms
 64 bytes from 192.168.56.102: icmp_seq=3 ttl=128 time=1.17 ms
 64 bytes from 192.168.56.102: icmp_seq=4 ttl=128 time=0.727 ms

--- 192.168.56.102 ping statistics ---
 4 packets transmitted, 4 received, 0% packet loss, time 3005ms
 rtt min/avg/max/mdev = 0.713/1.357/2.826/0.864 ms

kali@kali:~$ traceroute 192.168.56.102
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 60 byte packets
 1 * * *
 2 * * *
 3 * * *
 4 * * *
 5 * * *
 6 * * *
 7 * * *
 8 * * *
 9 * * *

```

```

Session Actions Edit View Help
kali@kali:~$ traceroute 192.168.56.102
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 60 byte packets
 1 * * *
 2 * * *
 3 * * *
 4 * * *
 5 * * *
 6 * * *
 7 * * *
 8 * * *
 9 * * *
10 * * *
11 * * *
12 * * *
13 * * *
14 * * *
15 * * *
16 * * *
17 * * *
18 * * *
19 * * *
20 * * *
21 * * *
22 * * *
23 * * *
24 * * *
25 * * *
26 * * *
27 * * *
28 * * *
29 * * *
30 * * *

kali@kali:~$ netstat -tulpn
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:80               0.0.0.0:*               LISTEN
tcp6       0      0 :::21                   :::*                    LISTEN

kali@kali:~$ nmap 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 04:11 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00066s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

```

[illegible][illegible]

```

kali@kali:~$
Session Actions Edit View Help
--$ dirb http://192.168.56.102

DIRB v2.22
by The Dark Raver

START TIME: Thu Aug 13 04:52:45 2026
URL_BASE: http://192.168.56.102/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

-- Scanning URL: http://192.168.56.102/ --
* http://192.168.56.102/cgi-bin/ (CODE:403|SIZE:295)
=> DIRECTORY: http://192.168.56.102/dav/
* http://192.168.56.102/index (CODE:200|SIZE:893)
* http://192.168.56.102/index.php (CODE:200|SIZE:1893)
* http://192.168.56.102/phpinfo (CODE:200|SIZE:148902)
* http://192.168.56.102/phpinfo.php (CODE:200|SIZE:48104)
=> DIRECTORY: http://192.168.56.102/phpmyAdmin/
* http://192.168.56.102/server-status (CODE:403|SIZE:300)
=> DIRECTORY: http://192.168.56.102/test/
=> DIRECTORY: http://192.168.56.102/testx/

-- Entering directory: http://192.168.56.102/dav/ --
(!) WARNING: Directory is LISTABLE. No need to scan it.
(Use mode "-w" if you want to scan it anyway)

-- Entering directory: http://192.168.56.102/phpmyAdmin/ --
* http://192.168.56.102/phpmyAdmin/calendar (CODE:200|SIZE:4145)
* http://192.168.56.102/phpmyAdmin/changelog (CODE:200|SIZE:74593)
* http://192.168.56.102/phpmyAdmin/Changelog (CODE:200|SIZE:40548)
=> DIRECTORY: http://192.168.56.102/phpmyAdmin/ctrl.php/
* http://192.168.56.102/phpmyAdmin/docs (CODE:200|SIZE:4583)
* http://192.168.56.102/phpmyAdmin/error (CODE:200|SIZE:1803)
* http://192.168.56.102/phpmyAdmin/export (CODE:200|SIZE:4145)
* http://192.168.56.102/phpmyAdmin/favicon.ico (CODE:200|SIZE:18902)
* http://192.168.56.102/phpmyAdmin/import (CODE:200|SIZE:4145)
* http://192.168.56.102/phpmyAdmin/index (CODE:200|SIZE:4145)
=> http://192.168.56.102/phpmyAdmin/index.php (CODE:200|SIZE:4145)
=> DIRECTORY: http://192.168.56.102/phpmyAdmin/js/
=> DIRECTORY: http://192.168.56.102/phpmyAdmin/lang/
=> DIRECTORY: http://192.168.56.102/phpmyAdmin/libraries/
* http://192.168.56.102/phpmyAdmin/license (CODE:200|SIZE:18011)
* http://192.168.56.102/phpmyAdmin/LICENSE (CODE:200|SIZE:18011)
* http://192.168.56.102/phpmyAdmin/main (CODE:200|SIZE:42273)
* http://192.168.56.102/phpmyAdmin/navigation (CODE:200|SIZE:4145)
* http://192.168.56.102/phpmyAdmin/phpinfo (CODE:200|SIZE:4)
* http://192.168.56.102/phpmyAdmin/phpinfo.php (CODE:200|SIZE:0)

```

## Question 2: Web Application Vulnerability Assessment

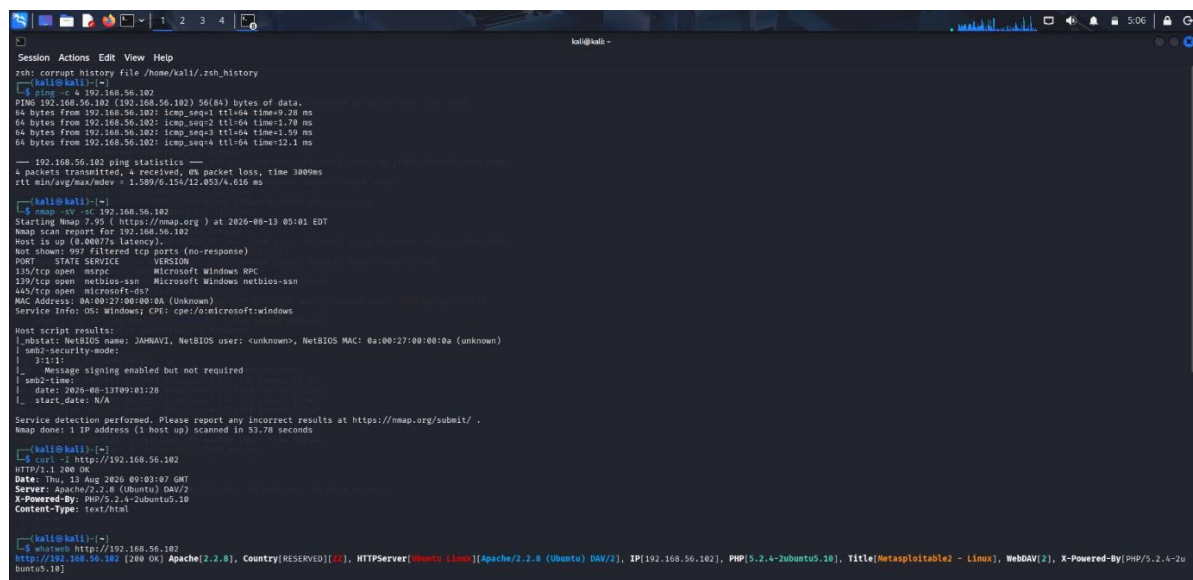
A cybersecurity analyst is assigned an authorized vulnerable web application in an isolated laboratory environment for security testing. You are required to identify the application's technologies and attack surface using appropriate reconnaissance techniques, examine input fields, parameters, cookies, sessions, and HTTP requests, and use suitable tools to identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory traversal, and security misconfigurations. Use tools such as Burp Suite, OWASP ZAP, Nikto, Nmap, Curl, and browser developer tools to analyze the application. Test the identified vulnerabilities only within the authorized laboratory environment, document the evidence and potential impact of each finding, classify the vulnerabilities according to severity, and recommend appropriate remediation and secure coding practices. Submit the commands/tool configurations, screenshots, observations, vulnerability findings, severity ratings, impacts, and recommendations.

**Aim:** To perform a vulnerability assessment of an authorized web application using Nmap, Nikto, Burp Suite, and OWASP ZAP in a controlled laboratory environment.

- **Target and Tools :** 192.168.56.102
- Application: Damn Vulnerable Web Application (DVWA)
- Operating System: Metasploitable 2 / Linux
- Tools Used: Nmap, WhatWeb, Nikto, Burp Suite, OWASP ZAP

## 1. Network and Service Identification

- ping -c 4 192.168.56.102
- nmap -sV -sC 192.168.56.102



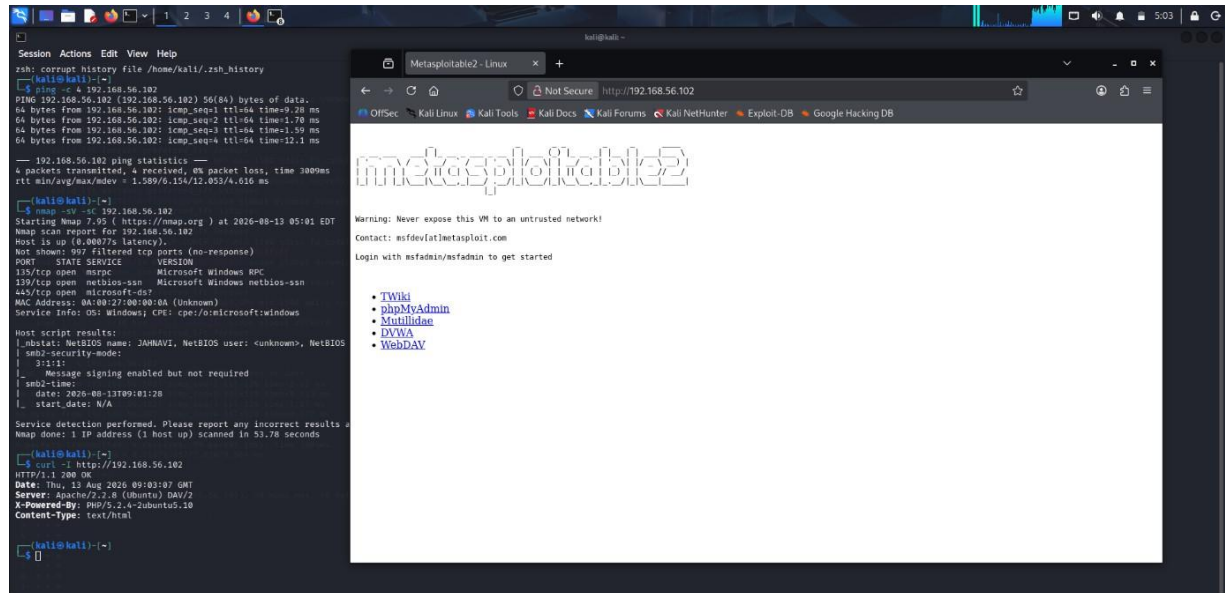
```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$
kali@kali:~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=9.28 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.78 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=12.1 ms
--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3809ms
rtt min/avg/max/mdev = 1.509/6.154/12.053/4.036 ms
kali@kali:~$
kali@kali:~$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-13 05:02 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00077s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc      Microsoft Windows RPC
139/tcp    open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 0A:00:27:00:00:0A (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ nbstat: NetBIOS name: JAHNAVI, NetBIOS user: <unknown>, NetBIOS MAC: 0a:00:27:00:00:0a (unknown)
|_ smb2-security-mode:
|   3.1.1:
|_   Message signing enabled but not required
|_ smb2-time:
|   date: 2020-08-13T09:01:28
|_   start date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.78 seconds
kali@kali:~$
kali@kali:~$ curl -s http://192.168.56.102
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2020 09:03:07 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
kali@kali:~$
kali@kali:~$ whatweb http://192.168.56.102
http://192.168.56.102 [200 OK] Apache[2.2.8], Country[RESERVED][0], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.56.102], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[2], X-Powered-By[PHP/5.2.4-2ubuntu5.10]
```

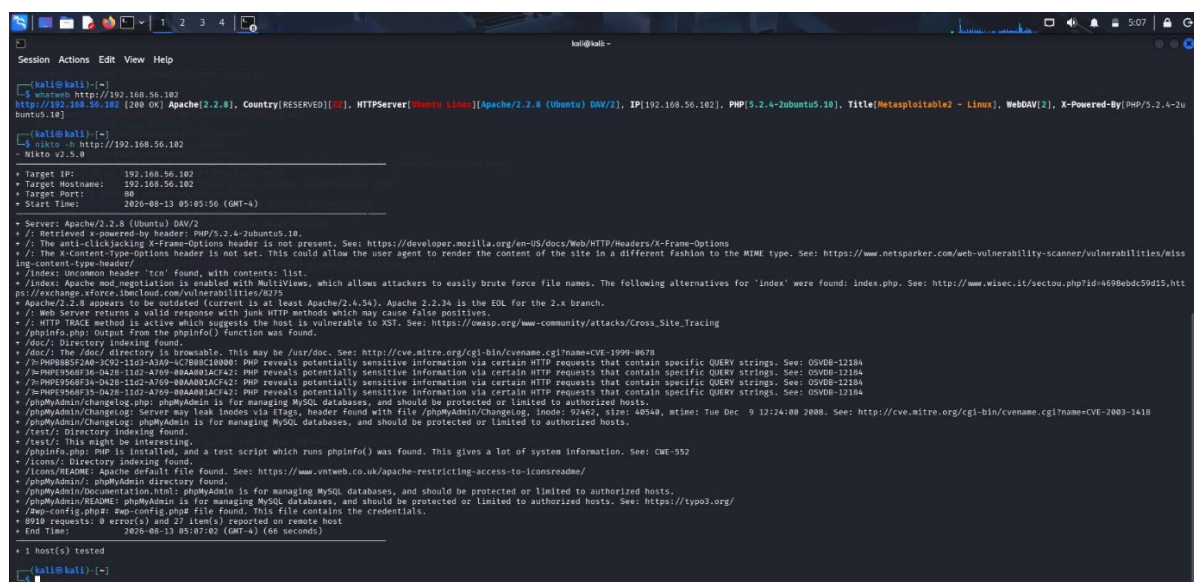
## 2. Web Technology Identification

- curl -I http://192.168.56.102
- whatweb http://192.168.56.102



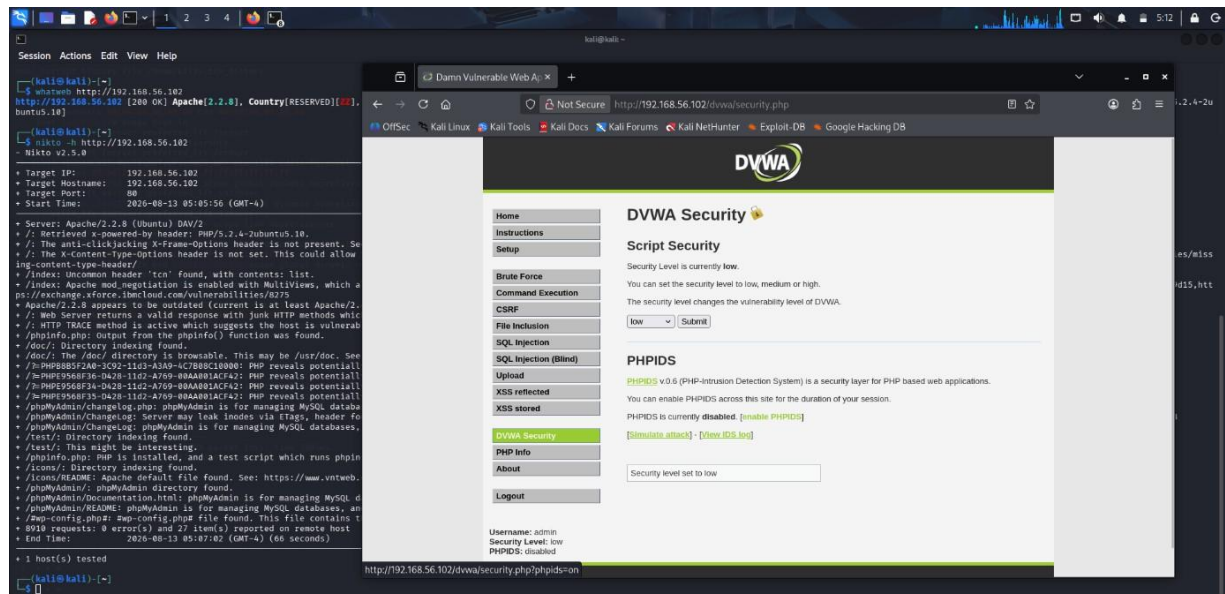
### 3. Nikto Web Server Scan

- nikto -h <http://192.168.56.102>

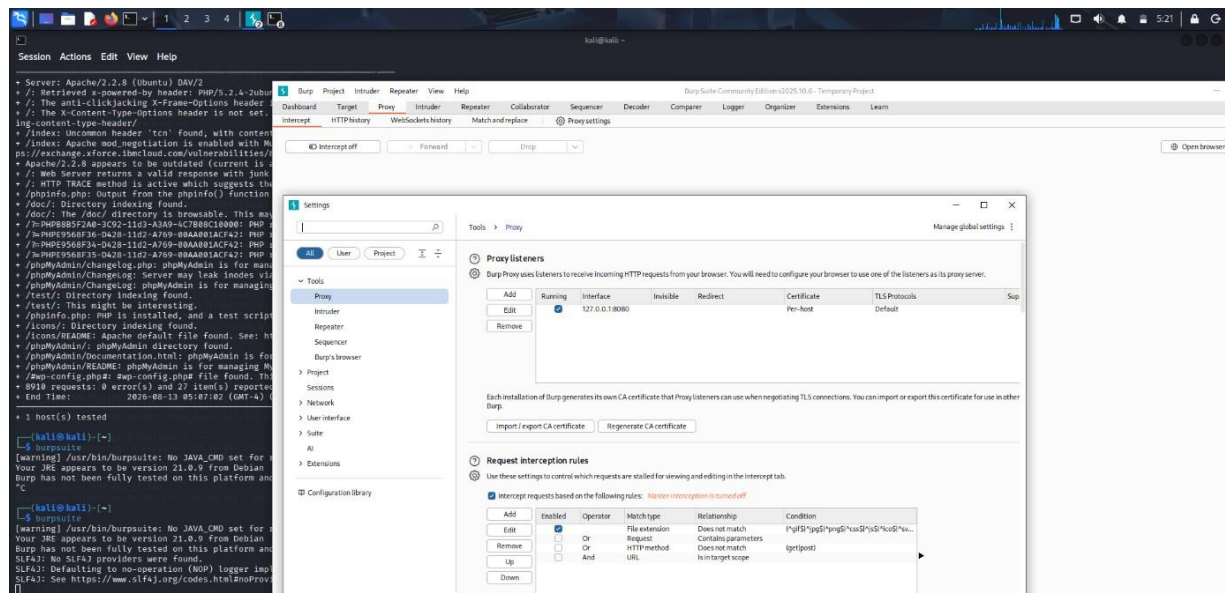




4. **DVWA Security Configuration** : The security level was configured to Low for controlled laboratory testing.

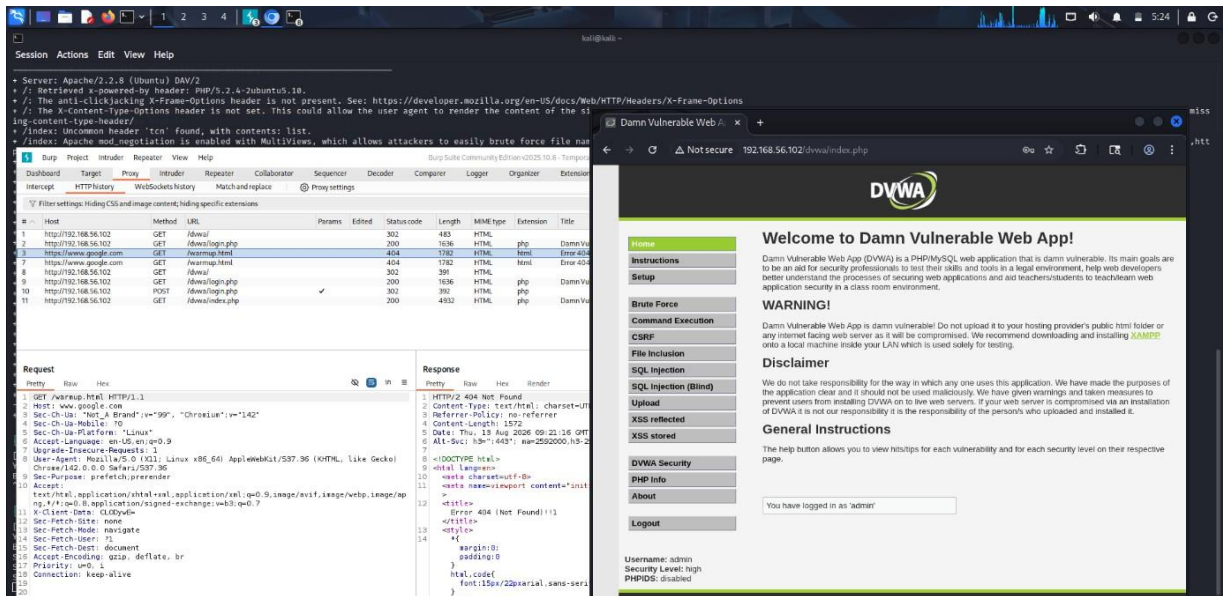


5. **Burp Suite Proxy Configuration** : The Burp Proxy listener was configured on 127.0.0.1:8080



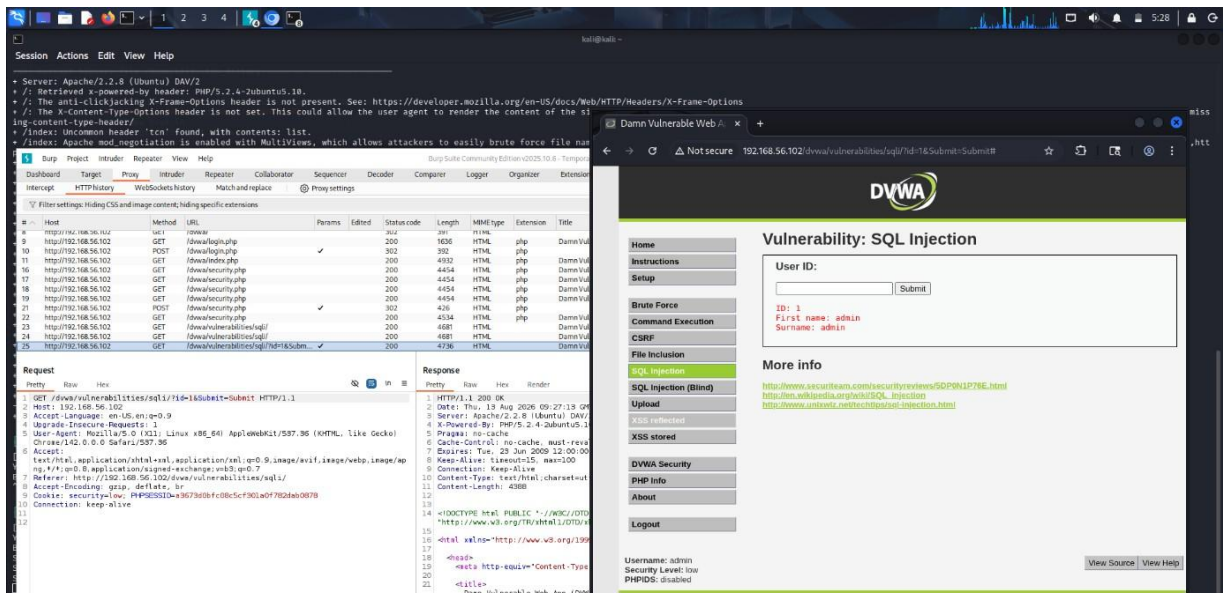
6. **Burp Suite HTTP History**

- DVWA requests were captured in Burp Suite HTTP History.
- GET and POST requests were observed.
- Login and application requests were recorded.



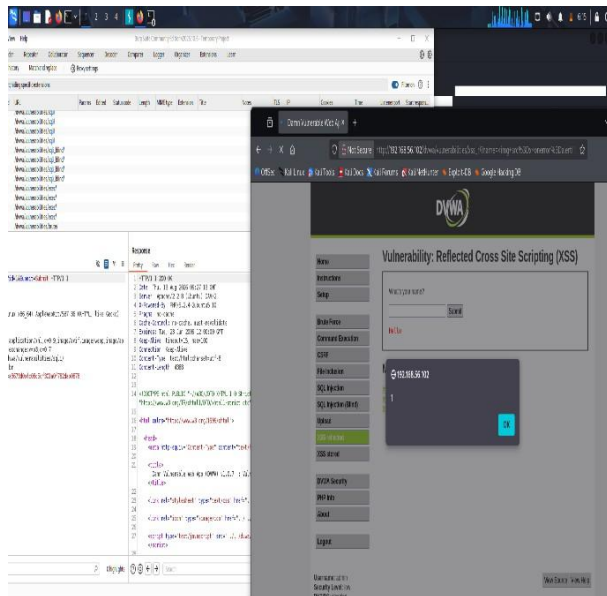
## 7. SQL Injection Testing

- DVWA SQL Injection module was opened.
- The id parameter was submitted.
- The request was captured using Burp Suite.



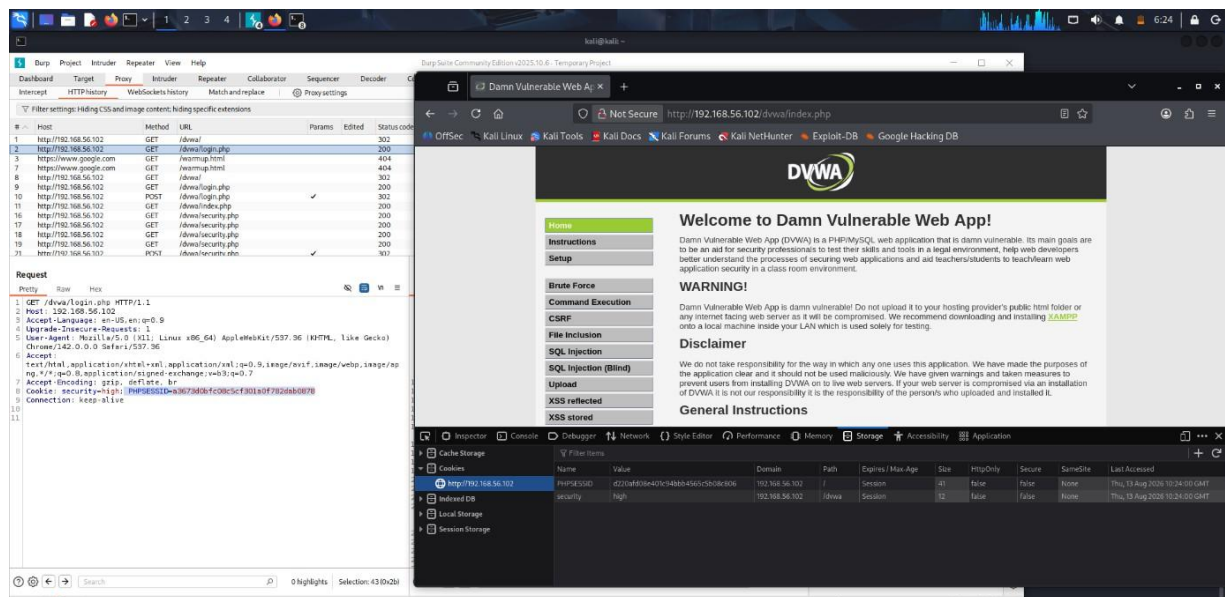
## 8. Reflected Cross-Site Scripting (XSS)

- DVWA Reflected XSS module was accessed.
- A JavaScript test input was submitted.



- Browser Developer Tools were used to inspect application cookies.
- The PHPSESSID session cookie was identified.
- Cookie security attributes were examined.

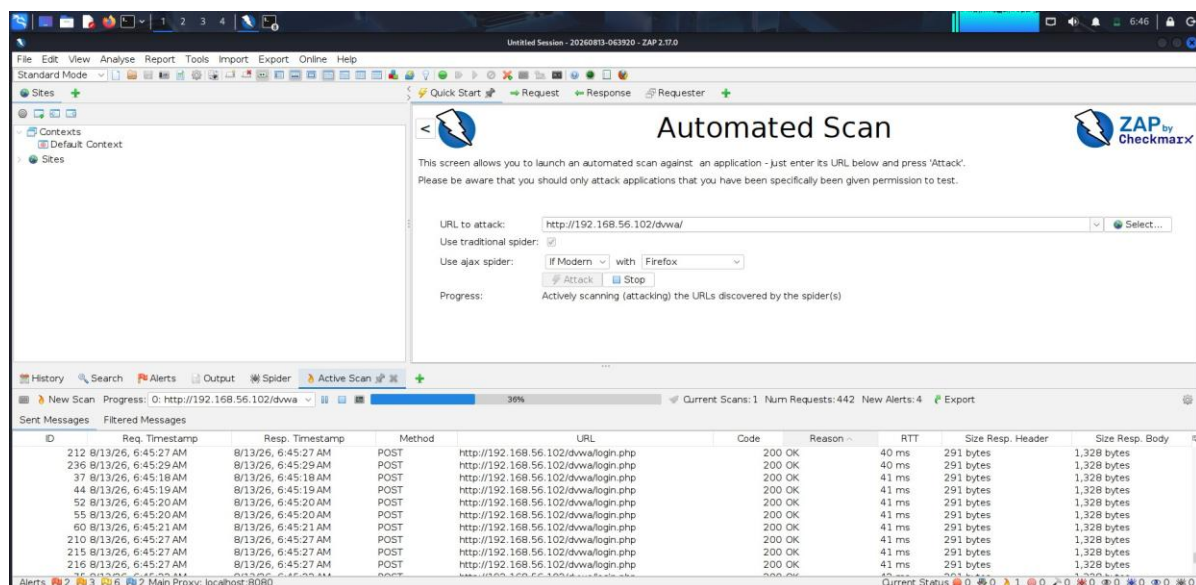
- Browser Developer Tools were used to inspect application cookies.
- The PHPSESSID session cookie was identified.
- Cookie security attributes were examined.



## 10. OWASP ZAP Automated Scan

Target : <http://192.168.56.102/dvwa/>

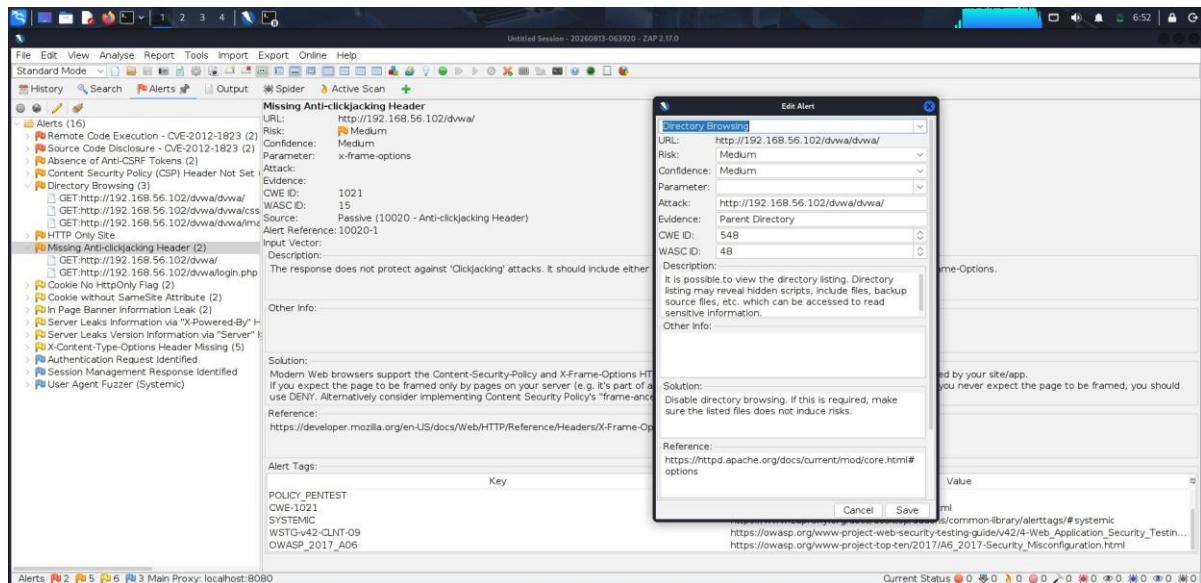
- 442 requests generated.
- 4 new alerts detected at that stage.



## 11. OWASP ZAP Security Findings :

- Directory Browsing.
- Missing Anti-clickjacking Header.
- Missing Anti-CSRF Tokens.
- Content Security Policy Header Not Set.





## 12. Conclusion :

The vulnerability assessment was successfully completed in the controlled DVWA/Metasploitable laboratory environment. The results demonstrate the importance of secure server configuration, input validation, HTTP security headers, session-cookie protection, and regular automated vulnerability scanning.

### Question 3: Security Header and HTTPS Configuration Assessment

A cybersecurity analyst is assigned an authorized web application hosted in an isolated laboratory environment to assess its HTTPS and security-header configuration. You are required to use Curl to examine HTTP response headers and Nmap SSL scripts to analyze the server's HTTPS/TLS configuration. Identify missing or improperly configured security headers such as Content-Security-Policy (CSP), HSTS, X-Frame-Options, and X-Content-Type-Options, and verify whether HTTP requests are automatically redirected to HTTPS. Examine the TLS configuration for weak protocols, insecure cipher suites, and certificate-related issues. Analyze the security purpose and potential impact of each misconfiguration, classify the findings according to their severity, and recommend appropriate HTTPS, TLS, certificate, and security-header hardening measures. Submit the commands used, screenshots, observations, identified risks, severity classification, and remediation recommendations.

**Aim :** To evaluate HTTPS, TLS, certificate, and HTTP security-header configuration using Curl and Nmap.

**Target:** 192.168.56.102 (Metasploitable 2)

**Tools:** Curl, Nmap

## **Commands Used :**

- curl -I http://192.168.56.102
- curl -k -I https://192.168.56.102
- curl -I http://192.168.56.102:443
- nmap -Pn -p 443 --script ssl-enum-ciphers 192.168.56.102
- nmap -Pn -p 443 --script ssl-cert 192.168.56.102

## **Practical Observations :**

HTTP returned 200 OK, but no HTTP-to-HTTPS redirect was observed. The HTTPS Curl request failed with wrong version number. A request using HTTP on port 443 returned 200 OK, indicating that port 443 was serving HTTP instead of properly negotiating TLS. Nmap detected port 443 as open but could not enumerate TLS ciphers or certificate information.

## **Findings and Severity**

- Missing HTTP-to-HTTPS redirection : Medium
- Missing CSP, HSTS, X-Frame-Options and X-Content-Type-Options : Medium/Low
- Improper HTTPS/TLS configuration on port 443 : High

## **Remediation**

Configure Apache to correctly serve HTTPS on port 443, use valid TLS certificates, redirect HTTP to HTTPS, disable obsolete TLS protocols, use strong cipher suites, and implement CSP, HSTS, X-Frame-Options and X-Content-Type-Options.

## **Result**

The web server's HTTPS and security-header configuration was successfully assessed. Multiple security-hardening deficiencies and an improperly configured HTTPS service were identified.

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ curl -k -I https://192.168.56.102
curl: (35) TLS connect error: error:8000100B:SSL routines::wrong version number

kali@kali:~$ curl -k https://192.168.56.102:443
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2020 12:13:31 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

kali@kali:~$ ssh -o HostKeyAlgorithms+ssh-rsa -o PubkeyAcceptedAlgorithms+ssh-rsa msfadmin@192.168.56.102
WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
linux metasploitable 2.6.24-10-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 1686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu Aug 13 07:39:32 2020 from 192.168.56.101
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
4: Listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
4: Listen 0.0.0.0:443
msfadmin@metasploitable:~$ sudo grep -nE 'VirtualHost|SSLEngine|SSLCertificate' /etc/apache2/sites-available/ssl-site
1:NameVirtualHost *
2:VirtualHost *:
09:0</VirtualHost>
on SSLEngine on
SSLCertificateFile /etc/apache2/ssl/server.crt
SSLCertificateKeyFile /etc/apache2/ssl/server.key
/etc/apache2/sites-available/ssl-site
msfadmin@metasploitable:~$ sudo /etc/init.d/apache2 restart
* Restarting web server apache2
[Thu Aug 13 08:10:58 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:10:58 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
[Thu Aug 13 08:17:08 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:17:08 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
...done.
msfadmin@metasploitable:~$ exit
logout
Connection to 192.168.56.102 closed.
```

```
kali@kali:~$ curl -k -I https://192.168.56.102
curl: (35) TLS connect error: error:8000100B:SSL routines::wrong version number

kali@kali:~$ nmap -Pn -p 443 --script ssl-enum-ciphers 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-14 00:32 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0014s latency).

PORT      STATE SERVICE
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 25.93 seconds

kali@kali:~$ nmap -Pn -p 443 --script ssl-cert 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-14 00:33 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0015s latency).

PORT      STATE SERVICE
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds

kali@kali:~$
```

## Question 4: Broken Access-Control Assessment

A cybersecurity analyst is assigned an authorized student portal in an isolated laboratory environment containing separate student and administrator test accounts. Using OWASP ZAP, capture and analyze requests generated while accessing student records and identify test object identifiers in URLs, forms, cookies, or API requests. Using only the test identifiers provided by the faculty, determine whether one student account can access another student's records or whether a normal user can directly access administrator-only resources. Compare the server responses for authorized and unauthorized requests, explain the difference between authentication and authorization failures, classify the identified access-control weaknesses based on their severity and impact, and recommend appropriate server-side authorization checks, role validation, and secure object-reference mechanisms. Submit the testing

procedure, commands/configuration, screenshots, observations, confirmed findings, severity, impact, and remediation measures.

**Aim :** To use OWASP ZAP to capture and analyze HTTP requests and responses of an authorized vulnerable web application and examine access-control related information.

### **Tools Used :**

- Kali Linux
- OWASP ZAP 2.17.0
- Metasploitable2
- Mutillidae web application

### **Procedure**

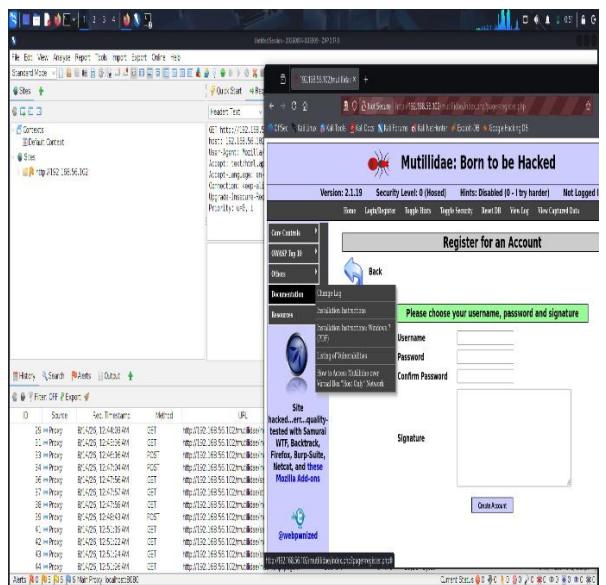
- ❑ Started OWASP ZAP in Kali Linux.
- ❑ Configured the browser to use ZAP as the proxy.
- ❑ Accessed the authorized laboratory server at 192.168.56.102.
- ❑ Opened the Mutillidae application.
- ❑ Navigated through the application while ZAP captured the generated HTTP requests.
- ❑ Opened History in ZAP and examined the captured requests.
- ❑ Analyzed request methods, URLs, parameters, cookies/session information and HTTP responses.
- ❑ Compared the request and response information to understand how authentication and authorization would be evaluated.
- ❑ Checked ZAP Alerts for security issues detected in the intentionally vulnerable application.

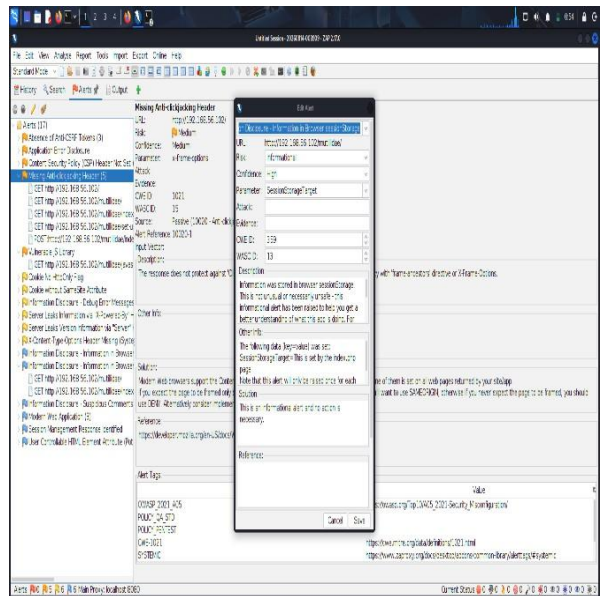
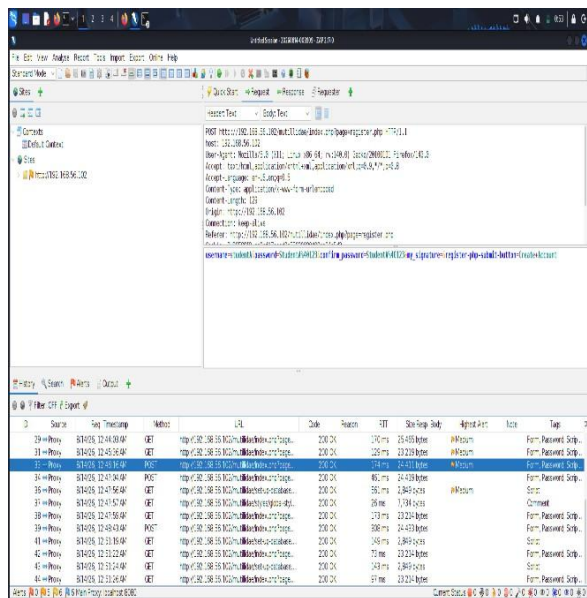
### **Commands / Configuration**

**Target:** http : //192.168.56.102/



**ZAP Proxy:** 127.0.0.1:8080





## Question 5: Automated Scanning and Manual Validation

A cybersecurity analyst is assigned an authorized web application hosted in a controlled cybersecurity laboratory for vulnerability assessment. Use Nikto to identify web-server misconfigurations and outdated components, and use Wapiti or OWASP ZAP to perform an automated web-application security scan. Compare the vulnerabilities reported by the selected tools and categorize them into misconfiguration, information disclosure, authentication, and injection issues. Select at least three findings for safe manual validation within the authorized laboratory environment and determine whether each finding is confirmed, a false positive, or requires further investigation. Assign an appropriate severity level based on likelihood and potential impact, and recommend practical remediation

measures for all confirmed vulnerabilities. Submit a comparative report containing tool outputs, screenshots, validation evidence, severity classification, remediation measures, and overall conclusions.

**Aim :** To identify web-server misconfigurations and web-application vulnerabilities using Nikto and OWASP ZAP, manually validate selected findings, classify their severity, and recommend remediation.

## **Target and Tools**

- Target: 192.168.56.102
- Nikto: Web-server vulnerability scanner
- OWASP ZAP 2.17.0: Web-application security scanner
- Browser & curl: Manual validation

## **Nikto identified:**

- ☐ Apache/2.2.8 and OpenSSL/0.9.8g outdated components
- ☐ Missing security headers
- ☐ Directory indexing in /doc/, /test/ and /icons/
- ☐ phpinfo.php information disclosure
- ☐ phpMyAdmin exposure
- ☐ Other server information disclosures

```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]~$
$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2020-08-14 01:10:26 (GMT+4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc39d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8225
+ mod_ssl/2.2.8 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OpenSSL/0.9.8g appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1b is current for the 1.x branch and will be supported until Nov 11 2023.
+ mod_ssl/2.2.8 OpenSSL/0.9.8g - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /bin/php805f2a0-3c92-11d3-a3a9-4c788c108000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: CVE-12184
+ /bin/php5968f34-0428-11d2-a769-80AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: CVE-12184
+ /bin/php5968f34-0428-11d2-a769-80AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: CVE-12184
+ /bin/php5968f34-0428-11d2-a769-80AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: CVE-12184
+ /phpMyAdmin/changeLog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: php is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /wp-config.php: wp-config.php file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 38 item(s) reported on remote host
+ End Time: 2020-08-14 01:11:33 (GMT+4) (65 seconds)

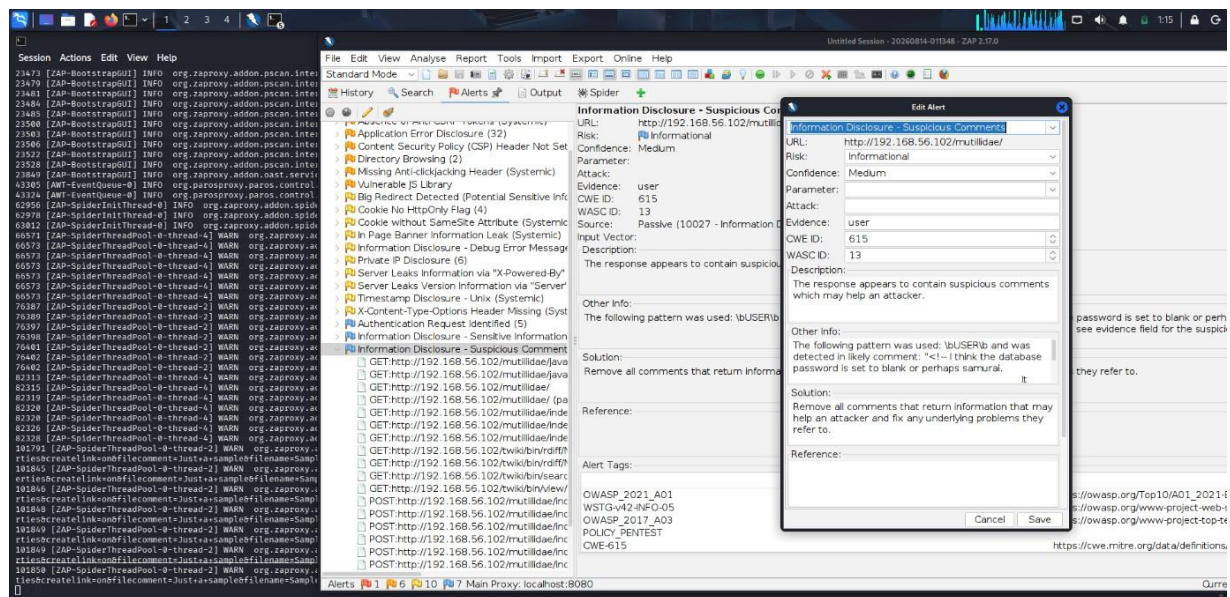
+ 1 host(s) tested

[kali@kali]~$
$ nc -v 192.168.56.102 80
Found Java version 21.0.9
Available memory: 1971 MB
```

## OWASP ZAP Results

ZAP reported:

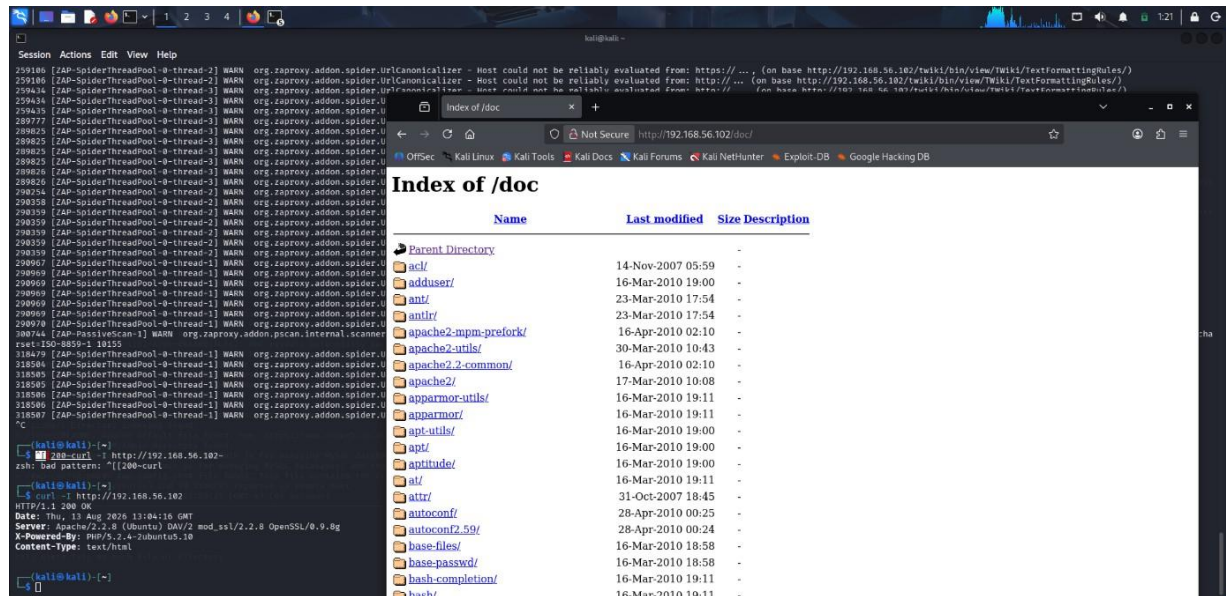
- ☐ Content Security Policy Header Not Set
- ☐ Directory Browsing
- ☐ Missing Anti-clickjacking Header
- ☐ X-Content-Type-Options Header Missing
- ☐ Cookie security issues



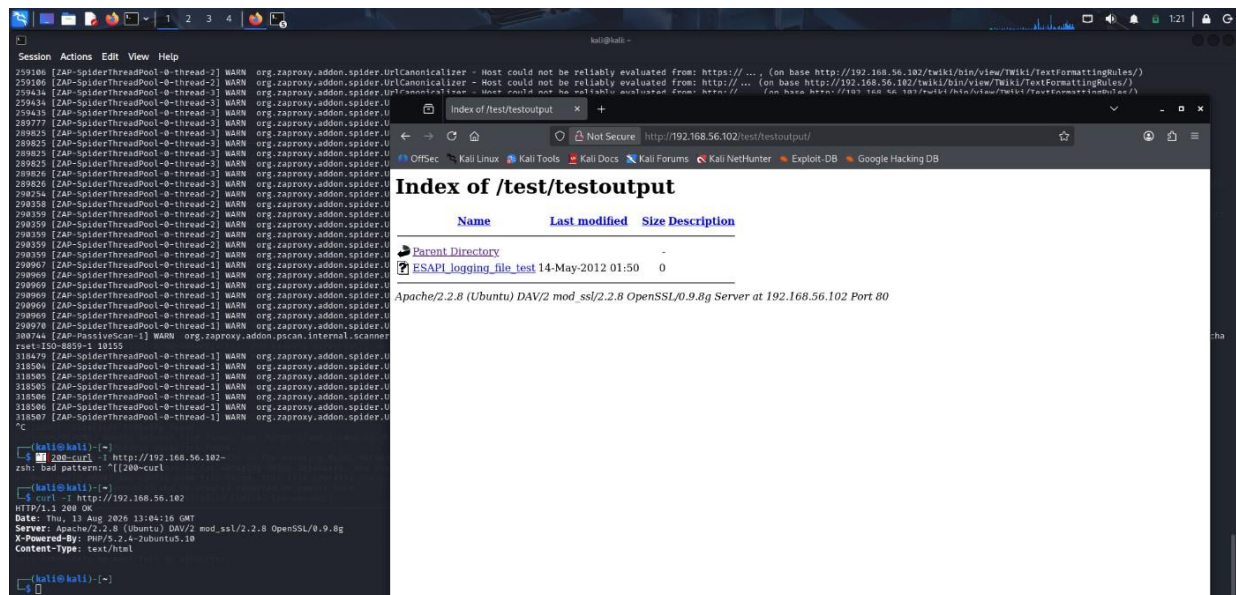
## 5. Manual Validation :

| Finding                  | Validation Evidence                                                                   | Result    | Severity   |
|--------------------------|---------------------------------------------------------------------------------------|-----------|------------|
| Missing security headers | curl -I<br>http://192.168.56.102 showed headers such as<br>CSP/X-Frame-Options absent | Confirmed | Low/Medium |
| Directory browsing       | /doc/ displayed Index of /doc with directory contents                                 | Confirmed | Medium     |
| Information disclosure   | Nikto identified phpinfo.php; browser validation performed                            | Confirmed | Medium     |





- Nikto provided stronger server-level findings, while ZAP provided broader web-application and HTTP security findings. Some findings, such as directory browsing and missing security headers, were identified by both tools.





## 6. Comparison

| Tool      | Main Purpose               | Findings                                                                                     |
|-----------|----------------------------|----------------------------------------------------------------------------------------------|
| Nikto     | Web-server assessment      | Outdated software, directory indexing, phpinfo, server misconfiguration                      |
| OWASP ZAP | Web-application assessment | Security headers, information disclosure, cookies, directory browsing and application alerts |

